教学设计方案 S05:IAM 认证授权与多租户

学习领域 LF2 | 第 5 周 | 授课教师版 | 180 分钟

1. 教学目标(布鲁姆分层)

- [应] 实现登录→取 token→携租户头调接口的完整脚本
- [解] 解释 JWT 三段结构与 claims(sub/roles/tenant_id)
- [析] 设计一条越权测试用例并解释预期

2. 教学重难点

- 重点:设计一条越权测试用例并解释预期
- 难点:解释 JWT 三段结构与 claims(sub/roles/tenant_id)
- 突破策略:情境导入(真实事故/需求)→知识建构精讲→真仓实训→检查互证→费曼外化

3. 教学准备

- 教学集群可用性预检(教师课前 30min);任务单打印/电子发牌;
- 情境素材核对:以 PLPP 最新 PROGRESS 阶段刷新本课情境(同步脚本拉取 project-references/)。

4. 180 分钟流程

环节	时长	教师动作	学生活动	观测点
A 情境导入	20'	讲情境、发任务单	领会工单、明确目标	能复述本课目标
B 计划	10'	巡视,不代拆	组内拆解分工	计划可执行
C 决策	5'	把关安全红线	30 秒方案陈述	红线重申到位
D 理论精讲	35'	按'知识建构要点'爬梯,层层提问	答+记笔记+追问	每层有应答
E 实施	70'	双师巡回,只提问不代写	真仓实操、记工单	步骤推进与证据留存
F 检查	15'	抽查	检查员勾验+互查	清单全过

环节	时长	教师动作	学生活动	观测点
G 评价+费曼	25'	评分点回收; 费曼只提问	费曼员上台	外行能懂

5. 理论精讲提纲(35min)

1) 认证 vs 授权

- 认证=你是谁(iam 签发 JWT);授权=你能干什么(roles+网关校验)
- 角色链:SUPER_ADMIN/ADMIN/TENANT_ADMIN/STUDENT

2) JWT 结构实测

- 三段 header.payload.signature;payload=claims
- 本平台实测:sub=用户 UUID, roles=["ADMIN","SUPER_ADMIN"], tenant_id=UUID
- 注意:token 放 Authorization: Bearer;租户放 X-Tenant-Id 头

3) 多租户隔离

- 数据隔离:租户字段过滤+行级隔离;接口隔离:@PreAuthorize 角色校验
- 越权用例模板:同租户低角色/跨租户同角色/无 token

6. 实训指导(70min)

1. **1. 登录**:POST /api/v1/auth/login + X-Tenant-Id + {username:admin,password:Admin@12345}
2. **2. 解码**:base64 解 payload,抄下 sub/roles/tenant_id 三值
3. **3. 业务调用**:携 token+租户头调 course 课程列表 → 200
4. **4. 越权实验**:换租户头调数据 / 无 token / 低角色三分支,记录结果

7. 布鲁姆提问设计(课堂穿插)

- [应] 现场演示…(实现登录→取 token→携租户头调接口的完整脚…)
- [解] 为什么…而不是…?(解释 JWT 三段结构与 claims(sub/…)
- [析] 如果…坏了,断在哪一跳?(设计一条越权测试用例并解释预期…)

8. 费曼讲题与引导

讲题:把 JWT 比作'景区手环':手环上写了什么?检票口认手环还是认脸?多租户=几个景区?
追问链:还有吗?→换个说法?→如果外行问…你怎么答?→一句话压缩?

9. 评价与作业

评分点:脚本可复用性(40%)+越权分支完整性(40%)+身份链讲解(20%) 作业:

- 费曼卡#5:JWT 手环类比 200 字
- 提交可复用登录脚本+越权用例文件

10. 板书设计

左板:本课目标(三层) | 中板:核心流程图(随精讲生长) | 右板:实训进度墙(各组勾验状态)